

Fase 7 — Observabilidad y Métricas

Taller WAAP · IA/ML · RASP · DevSecOps — Panel de métricas consolidado

Objetivo

Cerrar el ciclo de defensa en profundidad con visibilidad centralizada de los eventos de seguridad de las tres capas (WAF, IA/ML, RASP) y métricas que permitan justificar decisiones de ajuste (tuning) de las reglas y del modelo.

1. Centralización de logs

Los eventos de las tres capas se consolidaron en un único flujo JSON estructurado (waap/consolidate_logs.py → logs/eventos_consolidados.json), con campos comunes: timestamp, capa, payload, endpoint, veredicto, detalle y mttdd_ms_simulado. Esto permite correlacionar, filtrar y comparar eventos entre capas desde una única fuente, en vez de revisar tres formatos de log distintos por separado (texto plano de nginx/ModSecurity, CSV de resultados del modelo, y log de warnings de Python/Flask).

2. Tasa de detección, falsos positivos y falsos negativos por capa

Capa	Tasa de deteccion (TPR)	Falsos positivos (FPR)	Falsos negativos	Base de calculo
WAF (reglas)	80% (4/5)	0% (0/2)	20% (1/5)	Matriz Fase 6, 5 tecnicas
IA/ML	20% (1/5)	0% (0/5)	80% (4/5)	Matriz Fase 6 + umbral oficial -0.05
RASP	33% (1/3 aplicables)	0% (0/60)	67% (2/3 aplicables)	Matriz Fase 6 (XSS y bot excluidos, N/A por diseno) + prueba de latencia Fase 4

Nota sobre IA/ML: con un umbral más estricto (percentil 1 del tráfico normal, -0.01285, documentado en la Fase 3), la detección sube a 40% (2/5) pero el FPR se dispara a 80% (4/5) — un trade-off inaceptable que confirma la recomendación de mantener el umbral oficial.

3. Tiempo medio de detección (MTTD) simulado

Capa	MTTD simulado	Justificacion
WAF	~3 ms	Bloqueo sincronico en linea; el veredicto se emite dentro del mismo ciclo peticion-respuesta HTTP.
RASP	~2.5 ms	Bloqueo sincronico dentro de la aplicacion; medido en la prueba de latencia de la Fase 4 (con vs. sin RASP).
IA/ML	~5 min (simulado)	El modelo NO esta conectado al flujo de trafico en vivo: se ejecuta como script batch (score_request.py). El MTTD real depende de la frecuencia de ejecucion del job, no de la latencia por peticion. Se asume un intervalo ilustrativo de 5 minutos.

La diferencia de varios órdenes de magnitud entre las capas sincrónicas (WAF, RASP, milisegundos) y la capa asincrónica (IA/ML, minutos) es en sí misma un hallazgo relevante: en su implementación actual, el modelo de IA/ML no puede prevenir un ataque en tiempo real, únicamente detectarlo después del hecho durante su próxima ejecución batch.

4. Recomendación final de ajuste de umbrales

- Mantener el WAF (ModSecurity + OWASP CRS, PL1) como primera línea de defensa activa: mejor tasa de detección (80%), cero falsos positivos observados, y latencia despreciable (~3 ms).
- Mantener el RASP habilitado de forma permanente como capa complementaria: aunque su tasa de detección individual es menor (33%), cubre específicamente el escenario de fragmentación entre parámetros que el WAF no puede ver por diseño, con un costo de latencia estadísticamente insignificante.
- NO promover el modelo de IA/ML a una capa de bloqueo activo en producción en su estado actual. Se recomienda mantener el umbral oficial (-0.05) y operarlo únicamente en modo de monitoreo/alerta (logging), no de bloqueo, dado su 20% de tasa de detección. Subir la sensibilidad del umbral no es recomendable: la prueba con el umbral alternativo (-0.01285) multiplicó los falsos positivos a 80%, un nivel que generaría fatiga de alertas y fricción real a usuarios legítimos.
- Priorizar el reentrenamiento del modelo de IA/ML con tráfico más balanceado (actualmente dominado por búsquedas de autocompletado) y características adicionales (n-gramas de caracteres, proporción de símbolos especiales) antes de reconsiderar su uso como capa de bloqueo.
- Incorporar un componente dedicado de rate-limiting (ausente en las tres capas actuales): la ráfaga de peticiones tipo bot fue el único escenario que ninguna de las tres capas detectó, y en el caso del modelo de IA/ML incluso se clasificó como progresivamente MÁS normal a mayor volumen — el punto ciego compartido más crítico identificado en todo el taller.